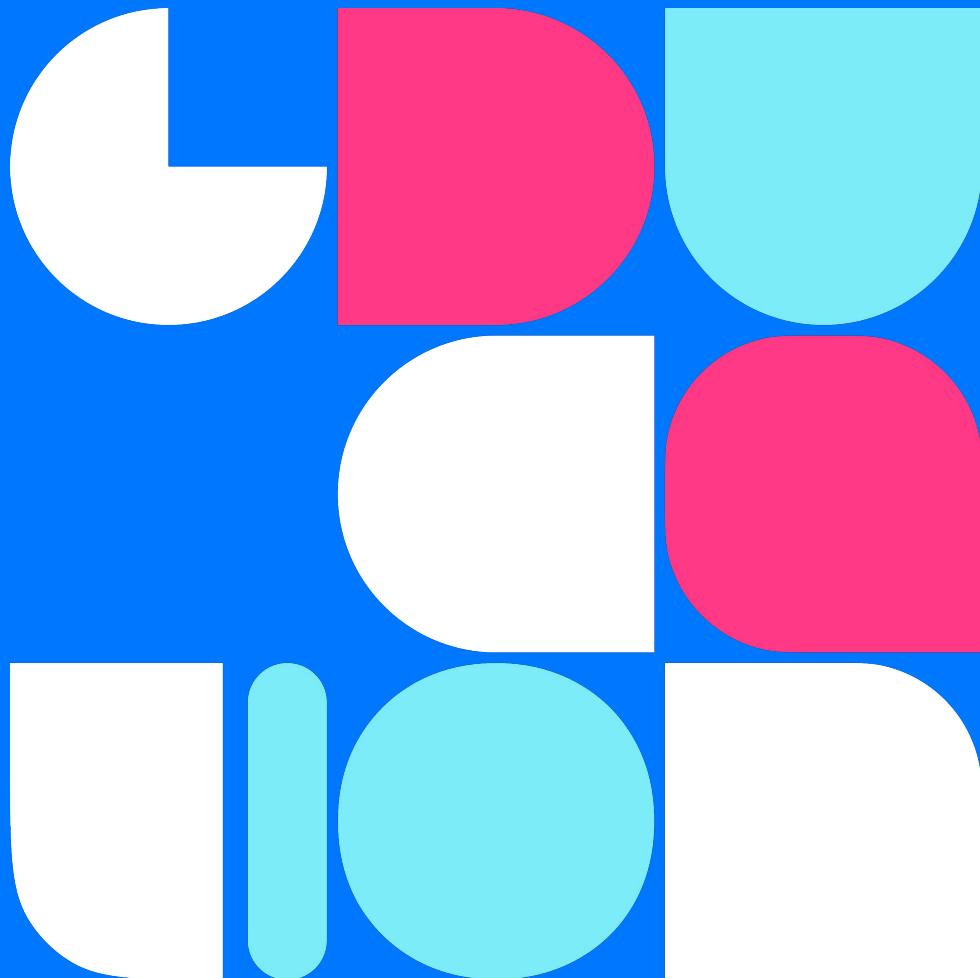




Безопасность приложений

Преподаватель: Степан Трифонов



Имя эксперта

Специалист по безопасности приложений
Защищаю рекламные продукты VK



Команда курса

Преподаватели:

- Степан Трифонов
- Александр Федченко
- Владислав Данилов
- Даниил Кокурин
- Иван Буряков

Актуальность курса



Актуальность курса

- Кибератаки ежегодно стоят компаниям миллиарды рублей
- Число кибератак на российские компании в первом полугодии 2025 года выросло на 27%
- В первые четыре месяца 2025 г. в России появилось около 42 000 вакансий в сфере информационной безопасности

Программа и логика курса



Курс состоит из:



всего 12 лекций
и семинаров



1 промежуточный
тест, 1 финальный
тест и экзамен



4 самостоятельных
практических задания

- Курс проходит с 7 октября 2025 по 18 декабря 2025 + время на экзамен
- Выдача сертификата после

Программа курса:

- Введение в информационную безопасность — лекция
- Основы Application Security — лекция
- Уязвимости в клиентской части веб-приложений — лекция
- Уязвимости в клиентской части веб-приложений — семинар
- Промежуточное тестирование
- Уязвимости в серверной части веб-приложений — лекция
- Уязвимости в серверной части веб-приложений: часть 2 — лекция
- Уязвимости в серверной части веб-приложений — семинар
- Уязвимости в мобильных приложениях — лекция
- Уязвимости в мобильных приложениях — семинар
- Основы безопасности инфраструктуры — лекция
- Основы безопасности инфраструктуры: часть 2 — лекция
- Основы безопасности инфраструктуры — семинар

Образовательные результаты

В результате обучения вы получите:

- Понимание принципов информационной безопасности, ролей в информационной безопасности и структуре ИБ в компаниях
- Базовое понимание принципов Application Security (AppSec), роли AppSec-инженера и процесса SSDLC (Secure Software Development Lifecycle)
- Понимание аспектов основных уязвимостей, актуальных для клиентской части Web-приложений
- Знание об топ-10 уязвимостях OWASP и о методологии их поиска и эксплуатации
- Знание об топ-10 уязвимостях OWASP и дополнительных возможных уязвимостях: о методологии их поиска и эксплуатации
- Знание об уязвимостях клиентской части Android-приложений, научиться их выявлять, предотвращать и применять методы защиты на практике
- Знание об основных уязвимостях мобильных приложений, методах их эксплуатации и защите, включая перехват трафика, атаки через WebView, XSS, MITM, фишинг, SSL Pinning и безопасное проектирование в рамках SSDLC
- Знание об инфраструктурной безопасности, безопасности ОС Linux, типовых угрозах в инфраструктуре, митигации и защите от них, а также сформировать знание о том, как работает IAC и как пишутся Ansible-плейбуки
- Базовые знание о Docker и Kubernetes, типовых уязвимостях в этих технологиях, мерах защиты и харденинг

Практические задания для самостоятельн ой работы



Практические задания для самостоятельной работы

- Всего 4 практических заданий
- Выдаются все после каждой лекции для самостоятельной работы
- Разбираются задания на семинаре

Важно!

- Вопросы по практике можно задать в чате
- Выполнять практику рекомендуем самостоятельно, без ChatGPT и помощи друзей, если действительно хотите закрепить навыки

Получение сертификата



Разбалловка по курсу

Количество баллов за курс	Оценка
61–74 балла	3
75–89 баллов	4
90–100 баллов	5

- Промежуточное тестирование — макс. 15 баллов, итоговое тестирование — макс. 15 баллов, экзамена — макс. 15 баллов, опрос — 10 баллов.
- Баллы можно увидеть на платформе в личном кабинете.

Как получить сертификат?

- Выдача сертификата на платформе происходит автоматически после окончания курса.
- Нужно набрать минимум 61 балл и полностью завершить курс, чтобы получить сертификат о прохождении.

Кому писать
с вопросами
и обратной
связью



Если что-то пошло не так...

Комьюнити-менеджер: Айрат Фахрутдинов

Команда тех. поддержки: info@education.vk.company

Обратная связь

- К каждому занятию на платформе
- В чате с преподавателями
- В конце курса будет обязательная форма обратной связи

Парковка для вопросов



Q: Зачем она нужна?

A: Вы можете оставить в ней вопросы по материалу прошлых лекций.

Q: Где её можно найти?

A: Ссылку на парковку можно найти в закреплённом сообщении в чате курса и в описании курса на портале

Q: В какой промежуток времени можно задать вопрос по материалу?

A: Вы можете оставлять свои вопросы сразу после окончания лекции. Форма закроется за 2 суток до начала следующей лекции.

Q: Когда ответят на мои вопросы, которые я оставил?

A: Преподаватель курса ответит на них в онлайн-формате на следующей лекции, либо передаст ответ в письменном виде в чат.



Как дойти до
конца курса
и получить
максимум
пользы



Идем до конца

- **Четко сформулируйте цель:** зачем вы пришли на курс?
Какой для вас идеальный результат по итогам обучения?
- **Учебные кризисы** — это нормально, главное вспоминать о своей цели.
Не бойтесь писать в чат и обмениваться поддержкой с одноклассниками
- **Тайм-менеджмент** — наше все. Вносите в календарь лекции и семинары, время на выполнение практических заданий и тестов
- **Интересуйтесь и не стесняйтесь задавать вопросы**
(глупых вопросов не бывает :))

Напутствие от экспертов курса

Введение в информационную безопасность

Безопасность приложений

№1

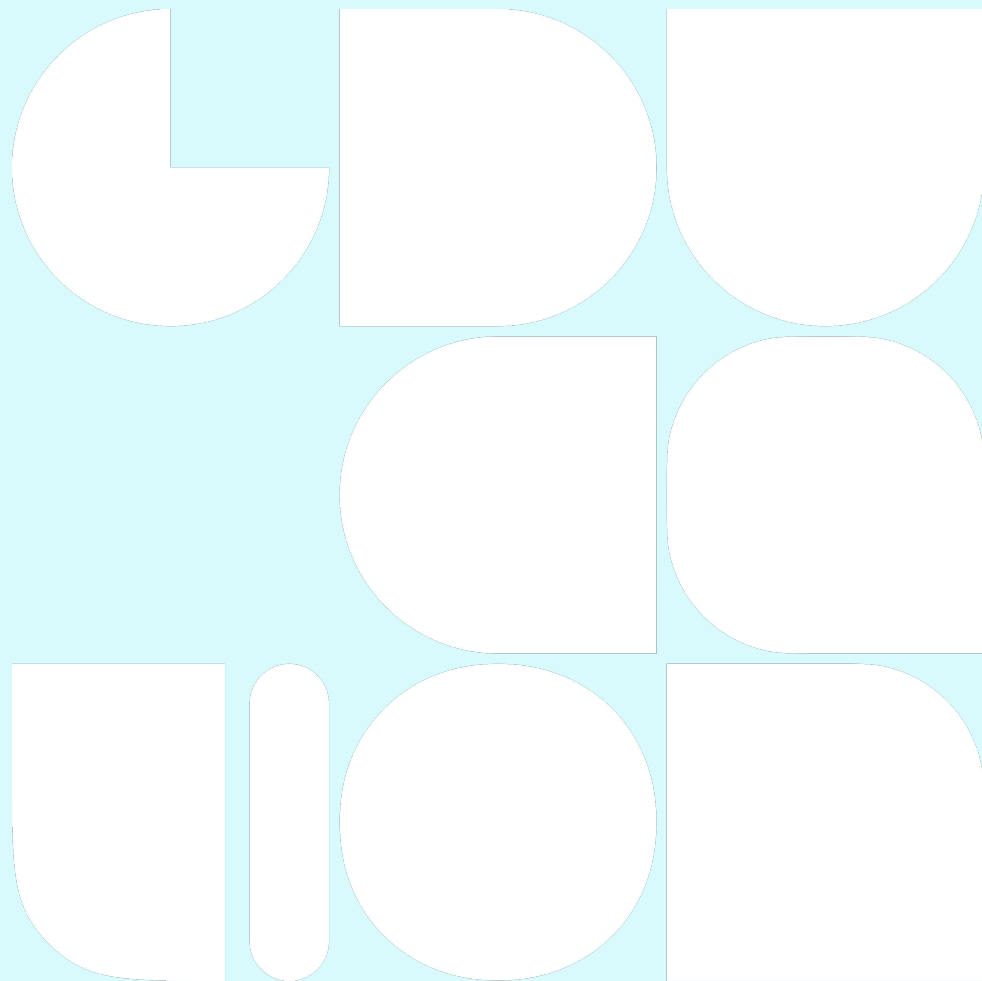


Цель занятия:

Сформировать базовое понимание принципов информационной безопасности, ролей в информационной безопасности и структуре ИБ в компаниях



Структура курса



Зачем этот курс?

- Дать теоретическую базу по безопасности приложений
- Порешать практические задания
- Задать вопросы экспертам

Темы лекций

- Введение в информационную безопасность
- Введение в безопасность приложений
- Уязвимости в клиентской части веб-приложений
- Уязвимости в серверной части веб-приложений (в 2-ух частях)
- Уязвимости в мобильных приложениях
- Основы безопасности инфраструктуры (в 2-ух частях)

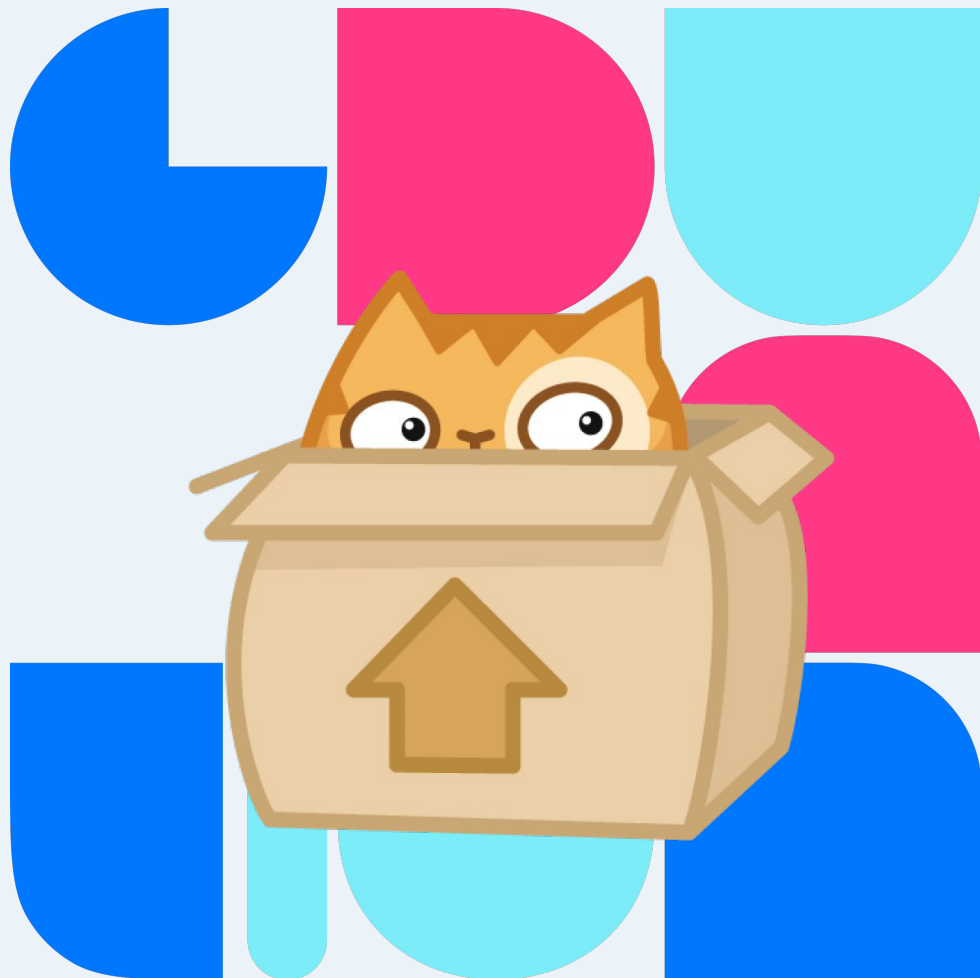
Домашние задания и семинары

- Каждую лекцию (начиная с 3-ей) преподаватель выдает лабораторные работы.
- Лабораторные работы решаются самостоятельно, затем (выборочно) разбираются преподавателем на семинаре, там же можно задать вопросы по лабам и просто по теме лекции.
- Всего 4 семинара — клиентсайд, серверсайд, мобильные приложения, инфраструктура.

Контроли

- Промежуточное тестирование (примерно после 5-ой лекции)
- Экзамен

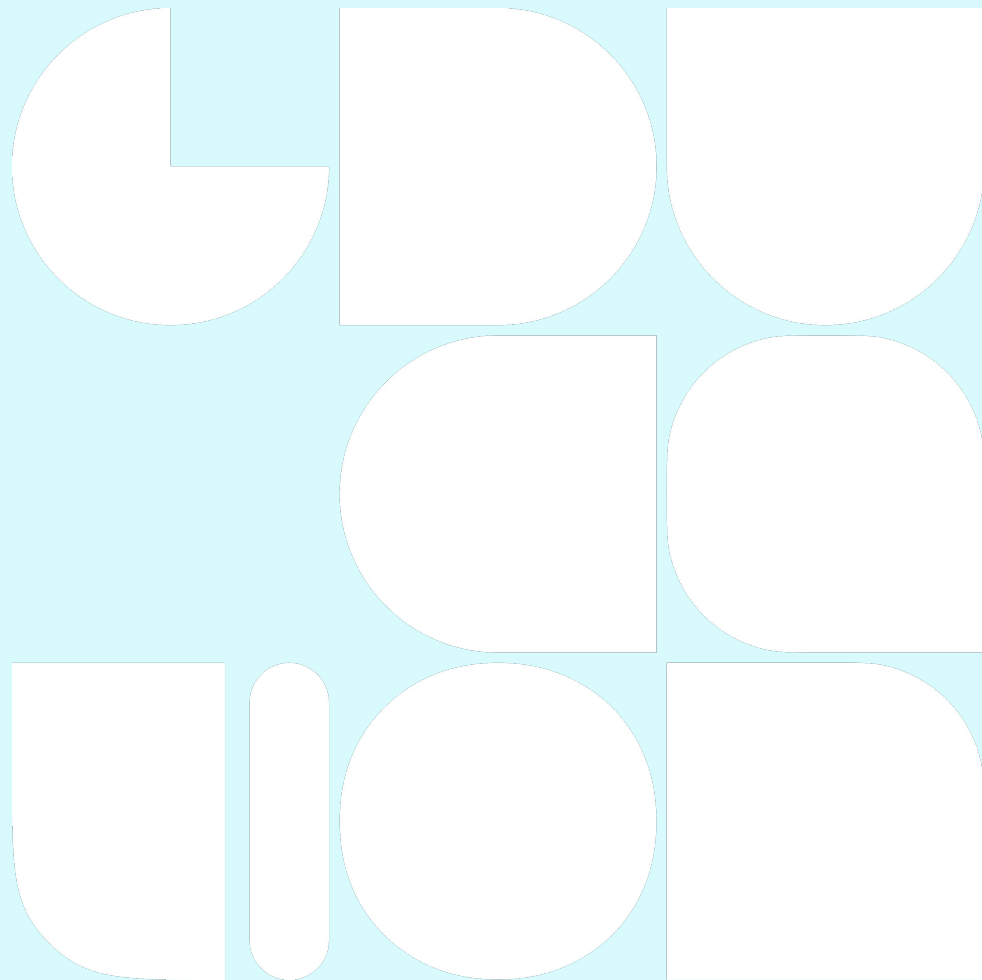
Вопросы?



О чём поговорим?

- Информационная безопасность в бигтехе
- Чем можно заниматься в ИБ

Информационная безопасность в бигтехе



Что такое информационная безопасность?

- **Безопасность информации** — состояние защищенности информации, при котором обеспечены ее конфиденциальность, доступность и целостность.
[ГОСТ Р 50922-2006, статья 2.4.5]
- **Защита информации** — деятельность, направленная на предотвращение утечки защищаемой информации, несанкционированных и непреднамеренных воздействий на защищаемую информацию.
[ГОСТ Р 50922-2006, статья 2.1.1]

Триада



Конфиденциальность

Защищает данные от несанкционированного доступа,
доступ к данным имеют только уполномоченные лица

Целостность

Данные являются точными и полными и не могут быть изменены и уничтожены несанкционированным способом, обеспечивает достоверность информации и не допускает ее искажения

Доступность

Данные доступны авторизованному пользователю в любое время
в необходимых объемах

Зачем ИБ большим компаниям

- Минимизация рисков атак и утечек информации (оборотные штрафы)
- Соответствие нормативным требованиям и стандартам
- Защита пользователей
- Минимизация репутационных рисков
- Обеспечение качества разрабатываемых систем

Регламенты и стандарты

- Внутренние стандарты (политика информационной безопасности, регламент по разработке безопасного ПО)
- Российские стандарты (ГОСТы, ФЗ, требования ФСТЭК)
- Международные стандарты (ISO, фреймворки оценки защищенности, PCI DSS)

Infosec Color Wheel



Blue Team

Команда защитников:

- Занимается мониторингом и реагированием на инциденты ИБ
- Расследует инциденты ИБ для понимания причин и последствий атак
- Внедряет и настраивает инструменты защиты
- Занимается управлением уязвимостями и их устранением

Red Team

Команда атакующих:

- Ищет уязвимости в приложениях, инфраструктуре и сетях
- Имитирует действия злоумышленников
- Тестируют защищенность компании (в том числе физическую)
- Проверяют осведомленность сотрудников (социальная инженерия)

Остальные команды

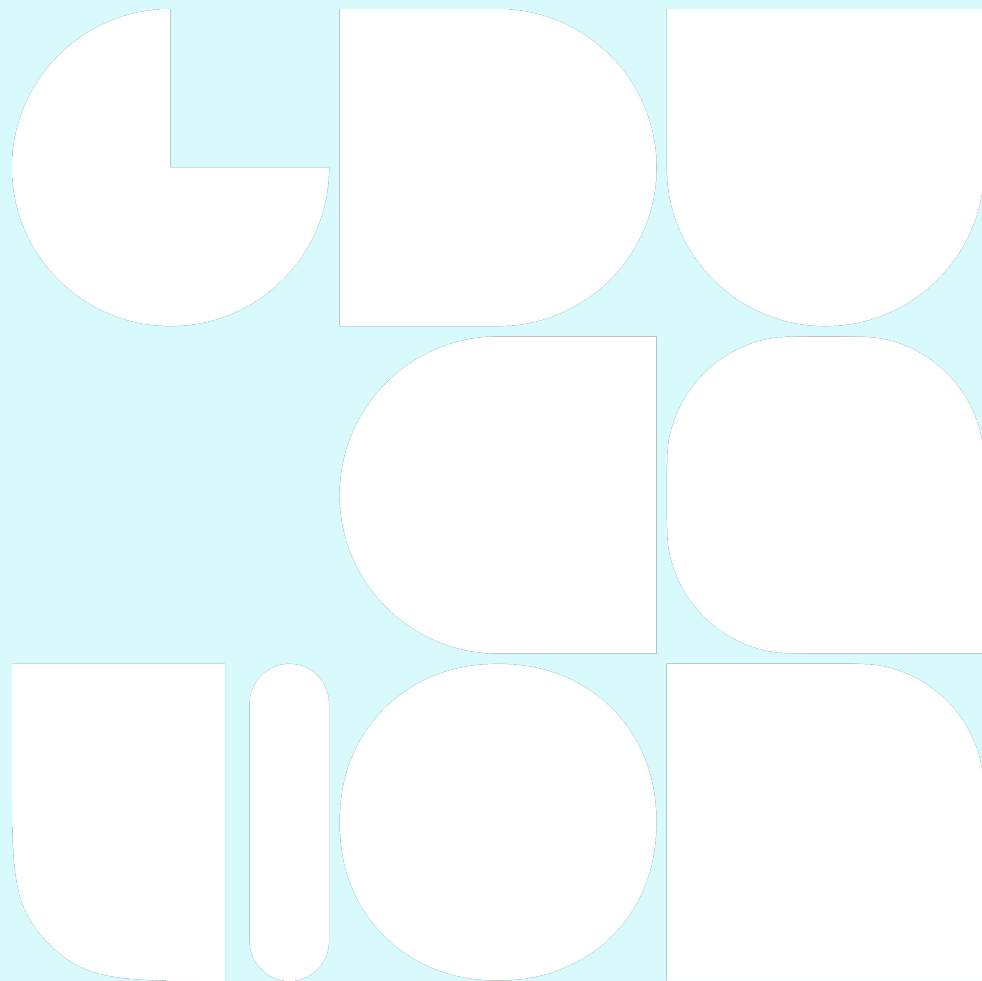


Итоги раздела:

- **Безопасность информации** — состояние защищенности информации, при котором обеспечены ее конфиденциальность, доступность и целостность.
- ИБ позволяет организации избежать утечек данных и репутационных рисков, защитить клиентов, обеспечить качество продуктов



Чем можно
заниматься в ИБ



Безопасность приложений

Appsec — практика защиты приложений от уязвимостей и атак.

Инженер по безопасности приложений:

- Тестирует веб-приложения на безопасность
- Внедряет и настраивает инструменты анализа приложений
- Взаимодействует с командами разработки для построения процесса безопасной разработки
- Участвует в архитектурном и feature ревью

Безопасность инфраструктуры

Безопасность инфраструктуры представляет из себя обеспечение защищенности серверов, контейнеров, оркестраторов контейнеров, IaC и прочего.

Инженер по безопасности инфраструктуры:

- Внедряет и настраивает инструменты анализа защищенности инфраструктуры, IDS/IPS, фаерволы и т.д.
- Проводит сканирование, патчинг и харденинг операционных систем и контейнерных сред
- Проводит ревью архитектуры и составляет требования к безопасной реализации на уровне инфраструктуры

Сетевая безопасность

Сетевая безопасность — процесс обеспечения защищенности внутренних систем компании.

Инженер по сетевой безопасности:

- Внедряет и настраивает инструменты сканирования и мониторинга внутренних сетей, фаерволы
- Участвует в проектировании сети компании
- Обеспечивает безопасный доступ в корпоративную сеть
- Отражает и митигирует DDoS-атаки

Тестирование на проникновение

Пентест — процесс имитации действий злоумышленника с целью выявить уязвимости в системе.

Специалист по тестированию на проникновение:

- Находит уязвимости в веб-приложениях, инфраструктуре, внутренней сети компании
- Прорабатывает сценарии эксплуатации уязвимостей с целью получить максимальный импакт
- Вырабатывает рекомендации по устранению уязвимостей

Security Operation Center

SOC — подразделение, отвечающее за выявление и отражение атак на компанию.

- L1: Обнаружение и первичная обработка инцидентов по плейбукам
- L2: Глубокий разбор и расследование инцидентов, реагирование на сложные инциденты, написание плейбуков для L1
- L3: Проактивный поиск сложных угроз, threat intelligence, помощь в расследовании отдельных инцидентов

Инженеры SOC: отвечают за работоспособность систем сбора логов и СЗИ, занимаются автоматизацией процессов внутри SOC.

Identity and Access Management

IAM — процесс управления учетными данными, ролями и привилегиями к компании.

Специалист по IAM:

- Составляет, внедряет и поддерживает модель доступа к информации и информационным системам внутри компании
- Имплементирует модели своевременной и безопасной выдачи доступов сотрудникам
- Внедряет лучшие практики, связанные с управлением учетными данными (MFA, SSO и т.д.)

Антифрод

Антифрод — практика выявления и предотвращения мошеннических действий.

Антифрод-аналитик:

- Занимается мониторингом действий на платформе с целью выявления фрода
- Разрабатывает модели и правила детектирования мошеннических действий
- Расследует инциденты, связанные с мошенничеством
- Подготавливает рекомендации по борьбе с фродом

Архитектура в ИБ

Архитектор ИБ отвечает за проектирование, создание и поддержку систем безопасности в организации, включая компьютерные системы и данные:

- Планирует, разрабатывает и валидирует архитектуру безопасности проектов
- Анализирует и оценивает безопасность инфраструктуры
- Создает, внедряет и сопровождает корпоративные процедуры и политики безопасности

Разработка в ИБ

В информационной безопасности, как и в любой сфере, необходимы разработчики с хорошим пониманием предметной области.

Разрабатывать можно множество инструментов:

- Сканеры безопасности
- Системы оркестрации других инструментов безопасности
- системы анализа логов обнаружения инцидентов
- Решения по безопасной выдаче доступов и безопасной работы с данными
- И многое другое

Security Awareness

Security Awareness — процесс повышения осведомленности сотрудников компании в вопросах ИБ:

- Обучение базовым принципам информационной гигиены
- Проведение тестовых фишинг-рассылок
- Обучение разработчиков базовым принципам безопасной разработки
- Сбор метрик эффективности обучения

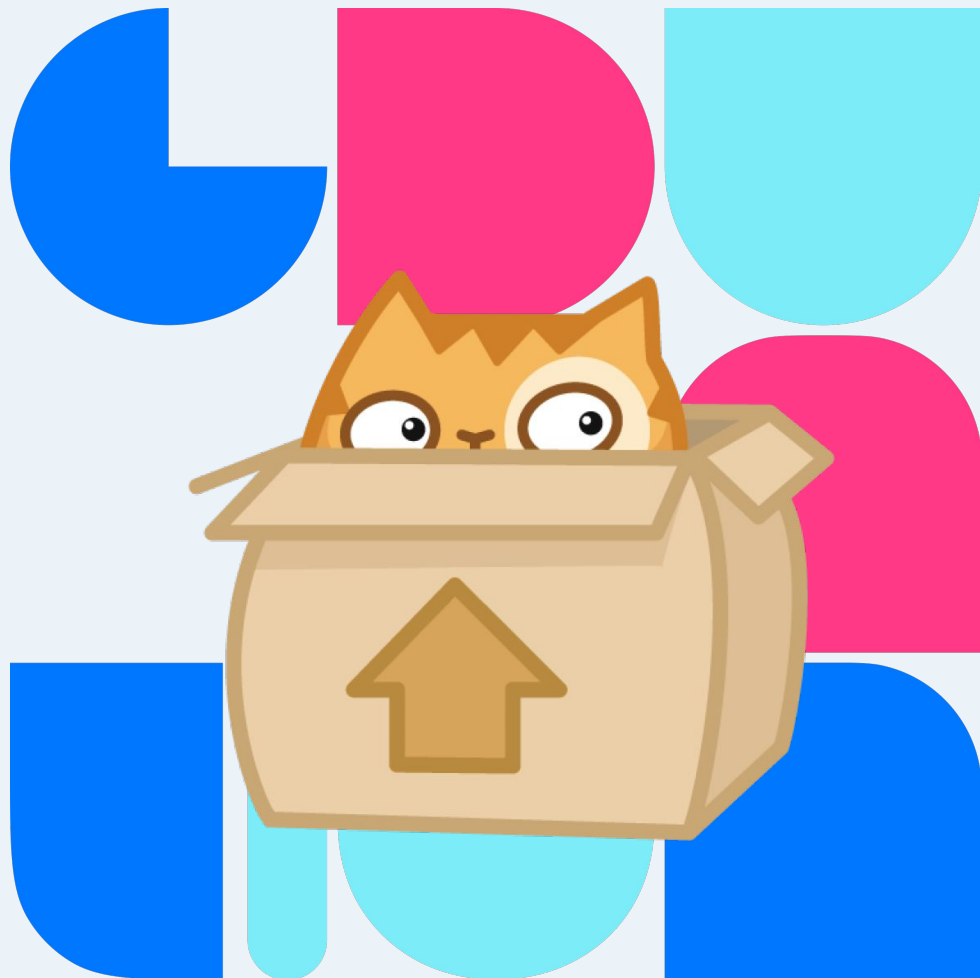
Bugbounty

Bugbounty — программа вознаграждения белых хакеров за найденные в приложении уязвимости.

Багхантеры исследуют утвержденные в программе домены (скоуп) на предмет уязвимостей, сдают отчеты.

На стороне компании-владельца программы сотрудники ИБ проводят разбор отчетов (триаж), принимают решение о вознаграждении.

Вопросы?



Подведем итоги:

- Информационная безопасность состоит из трех компонентов: конфиденциальности, целостности и доступности
- Соблюдение мер защиты информации в компании позволяет компрометации систем и утечек данных, защитить пользователей и не допустить репутационных потерь
- В информационной безопасности существует множество подразделений и ролей (например, специалист по безопасности приложений, специалист по безопасности инфраструктуры, пентестер, аналитик SOC, архитектор ИБ и прочие), требующих разных навыков и умений

Дополнительный материал:

- ГОСТ Серия ИСО/МЭК 27000 — Информационные технологии. Методы и средства обеспечения безопасности.
- NIST SP 800-12 Rev. 1 — An Introduction to Information Security
- Jason Andress, Foundations of Information Security: A Straightforward Introduction

Спасибо за
внимание!

